

SISTEMA DE GESTIÓN DE INVENTARIO MULTIENTPRESA CON CONTROL DE ACCESO POR API KEY

(FastAPI + PostgreSQL)

1. Contexto del problema

La empresa **InvenTrack** requiere desarrollar un sistema backend para la gestión de inventario que permita administrar productos y categorías en un entorno multiempresa.

El sistema debe soportar múltiples compañías (identificadas por RNC) que consumen la API mediante claves de acceso (API Keys). Cada API Key define:

- Qué empresas pueden usarla
- En qué países puede operar
- Qué datos puede consultar

El objetivo principal es implementar un sistema seguro, escalable y auditable utilizando **FastAPI** y **PostgreSQL**.

2. Tecnologías requeridas

- FastAPI
 - PostgreSQL
 - SQLAlchemy o SQLModel
 - Alembic (migraciones)
 - Pydantic (validaciones)
-

3. Modelo de datos

3.1 country

Representa los países disponibles en el sistema.

Atributos:

- id (PK)
- code (string, único) → ISO code (DO, US, VE, etc.)
- name (string)
- active (boolean)

3.2 api_key

Representa las credenciales de acceso a la API.

Atributos:

- id (PK)
- key_hash (string) → API Key almacenada en formato hash
- name (string) → descripción o identificador de la key
- active (boolean)
- created_at (timestamp)
- expires_at (timestamp, opcional)

3.3 api_key_country

Define los países donde una API Key tiene permiso de operar.

Atributos:

- api_key_id (FK → api_key.id)
- country_id (FK → country.id)

Restricción:

- Clave primaria compuesta (api_key_id, country_id)

3.4 company

Representa las empresas clientes del sistema (identificadas por RNC).

Atributos:

- id (PK)
 - rnc (string, único)
 - name (string)
 - country_id (FK → country.id)
 - active (boolean)
 - created_at (timestamp)
-

3.5 api_key_company

Relaciona API Keys con empresas (RNC).

Atributos:

- api_key_id (FK → api_key.id)
- company_id (FK → company.id)

Restricción:

- Clave primaria compuesta (api_key_id, company_id)
-

3.6 category

Representa las categorías de productos.

Atributos:

- id (PK)
 - name (string, único)
 - description (text, opcional)
 - active (boolean)
 - created_at (timestamp)
 - updated_at (timestamp)
-

3.7 product

Representa los productos del inventario.

Atributos:

- id (PK)
- sku (string, único)
- name (string)
- description (text)
- price (decimal)
- stock (integer)
- category_id (FK → category.id)
- country_id (FK → country.id)

- active (boolean)
 - created_at (timestamp)
 - updated_at (timestamp)
-

3.8 request_log

Tabla de auditoría para registrar todas las solicitudes a la API.

Atributos:

- id (PK)
 - api_key_id (FK → api_key.id)
 - company_id (FK → company.id, nullable)
 - endpoint (string)
 - method (string)
 - status_code (integer)
 - country_id (FK → country.id, nullable)
 - ip_address (string, opcional)
 - created_at (timestamp)
-

4. Autenticación y autorización

Cada solicitud a la API debe incluir los siguientes headers:

Header obligatorio

X-API-Key

- Obligatorio en todas las peticiones
 - Representa la clave de acceso del cliente
 - Se almacena en base de datos en formato hash
 - Se valida comparando el hash, nunca el valor plano
-

Header opcional

X-API-User

- Representa el RNC de la empresa cliente
 - Una API Key puede estar asociada a varias empresas
 - Puede usarse con fines de auditoría o trazabilidad
-

5. Reglas de negocio

5.1 Validación de API Key

- Si la API Key no existe o está inactiva → 401 Unauthorized
-

5.2 Validación de empresa

- Si se envía X-API-User:
 - Debe estar asociada a la API Key
 - Si no está asociada → 403 Forbidden
-

5.3 Validación por país (scope)

- Cada API Key tiene acceso limitado por países definidos en api_key_country
 - Si el recurso solicitado pertenece a un país no permitido:
→ 403 Forbidden
-

5.4 Auditoría

Cada solicitud debe registrarse en request_log con:

- API Key utilizada
- Empresa (si aplica)
- Endpoint consumido
- Método HTTP
- Código de respuesta
- País del recurso
- Fecha y hora
- IP del cliente

6. Endpoints mínimos requeridos

Categorías

- POST /categories
- GET /categories
- GET /categories/{id}
- PUT /categories/{id}
- DELETE /categories/{id}

Productos

- POST /products
- GET /products
- GET /products/{id}
- PUT /products/{id}
- DELETE /products/{id}
- GET /products?category_id=&country_id=&active=

7. Requisitos técnicos

- Uso de UUID en tablas principales
- Validación con Pydantic
- Arquitectura modular:
 - routers/
 - models/
 - schemas/
 - services/
 - core/security/
- Middleware global para autenticación
- Middleware o dependencia para validación de país

- Hashing seguro de API Keys
 - Manejo centralizado de errores
-

8. Casos de prueba obligatorios

1. Petición sin API Key → 401 Unauthorized
2. API Key inválida → 401 Unauthorized
3. Empresa no asociada → 403 Forbidden
4. Acceso a país no permitido → 403 Forbidden
5. CRUD completo con autorización válida → 200 / 201